Name- Finish Ajit Bapat
Roll No - 4401042600 5 Department: FYBCA

M T W T F S S
Page No.:
Date: YOUVA

12/10/2026 Case Study 02:

* Case Study: Securing the University Examination System.

A university uses an operating System-based examination management system to store student records, examination marks, faculty details, and question papers. The System has three main user groups: Students, Faculty and administrators. Students should be able to view only their own marks and download permitted learning materials. Faculty members need to view student records and enter or modify marks. Administrators manage user accounts, permissions, and system configuration.

The university has assigned permissions through roles, but an audit review identifies the following events:

- At 10:00, the account Student 07 has three failed login attempts.
- At 10:03, Student 07 successfully ~~login~~ logs in.
- At 10:04, Student 07 attempts to open Exam marks for an entire class.

- At 10:05, the system records an attempted modification of Exammarks.xlsx by student 07.

- At 10:15, faculty 02 modifies marks in Exam marks.xls and saves the file successfully.

- At 10:20, an administrator discovers that a former faculty member's account is still active.

- The audit log is stored on the same server, and users with broad permissions may be able to modify or delete it.

The university wants to protect confidentiality, integrity, and availability; prevent unauthorized access; maintain accountability, and investigate suspicious activity. You are asked to recommend appropriate operating system access-control, security administration, and auditing measures.

Questions:

Q.1) Identify the main security problems in the case study.

List at least four risks or weaknesses indicated by the scenario.

Q.2) Explain the difference between authentication and authorization using student ID as an example.

Distinguish identity verification from permission checking.

Q.3) Recommend an access-control policy for students, faculty, and Administrators. Justify your choice.

consider how permissions should be assigned and managed.

Q.4) Prepare a suitable Access control List (ACL) for Exam marks. 1 x 5.

Specify appropriate Read, Write, and Delete permissions for each user group.

Q.5) Explain how the principle of least priviledge should be applied in this system.

State what each group needs to do which unnecessary permissions should be removed.

Q.6) Interpret the audit events from 10:00 to 10:05. what should the security team to do next.

Explain why the sequence is suspicious without assuming that it proves an attacks.

Q.7) Identify at atleast five events that should be recorded in audit logs.

Include login, file, account, permissions, and/or administrative events.

Q.8) Explain why the audit logs must be protected and recommend two ~~day~~ ways to protect them.

consider unauthorised modification, deletion and investigation.

Q.9) What action should be taken regarding the former faculty member's active account? Explain

Relate your answer to account management and access removal.

Q.10) Suggest a Practical incident-response and corrective-action plan for the university.

Include investigation, access review, policy changes, and follow-up monitoring

Answers:

Q.1)

→ 1. Students can access blocked files: Student 07 was able to try opening and editing the main mark sheet.

2. old accounts left open: A former teacher's account was still active and usable.

3. Log files are unsafe: The activity history (logs) can be modified or erased by bored users on the same server.

4. Weak login protection: Student 07 guessed the password multiple times before logging in and trying to access private records.

Q. 2)

→ Authentication: Proves who are you

Example: Student 07 typing the correct password to log in at 10:03.

Authorization: checking what you are allowed to do.

Example: The system checking if student 07 is allowed to open the whole class's mark or edit files.

Q.3)

→ Students: can only view their own personal marks and download study material.

Teachers: Can view Student records and enter /change marks only for their own classes.

Administrators: Can create or delete user accounts and manage settings, but cannot edit student grades directly.

Q.4)

→ Students: cannot Read, write, Delete exam marks.

Teacher: can Read and write exam mark but cannot Delete.

Administrators: can Read, limited acces for writing and cannot Delete.

Unauthorized users: They cannot Read, write & Delete.

Q.5)

→ Principle of least priviledge gives only necessary access.

Give users only the permissions they need to do their work and remove everything else:

- Students: Need to see their own marks. Remove: access to whole-class Spreadsheets or edit options.
  update grades

Teachers: Need to ~~upgrade~~ for their subject. Remove: access to other teachers class or administrative control.

Admins: Need to manage System Settings
Remove: ability to change Stude
n; grades or wipe activity
logs.

Q.6)

→ It is suspicious because first ~~their~~ there were 3 wrong passwords attempts followed by a succesful login, the immediately trying to open and edit sensitive exam files. This could be a student guessing someones password or trying to cheat.

The measures that shold haire taken could be, Temporerily lock student 07's account, check where the login came from and talk to the student to find out what happened.

Q.7)

→ 1. Successful and failed login attempts.

2. ~~Any~~ attempt to open or edit marking sheets.

3. Creation or deletion of user accounts.

4. Password changes or resets.

5. Changes made to System Settings or user permissions.

Q.8)
→ Logs prove what happened during a security incident. If someone can delete them, they can cover their tracks.

We can protect them by sending those logs to a Sperate server and make them ~~read~~-only.

Q.9) University
→ ~~IATE~~ should disable and delete the account because unused active accounts are open doors for hackers. Whenever an employee leaves their account should be logged out completely.

Q.10)
→ The university should investigate the problem and locks the involved accounts.

Then they should review their accounts and delete any old or inactive account.

They should set the lock automatically after certain numbers of unsuccessful attempts to log in.

They should ~~MONITY~~ monitor the logs regularly which will help them to catch suspicious behaviour befor hand.